PROJET CAPSTONE

Éthique & Sécurité

Conformité RGPD

Données de santé, pseudonymisation, droits des personnes et gouvernance — Système Intelligent de Détection de Fraudes Médicales, d'Optimisation des Remboursements Santé & d'Assistant Agentique

Réalisé par :

ANDRIAMBOLOLONA Riantsoa Cherica
OLIVETTE Jason Brad Mirado
ANDRIAMIHAJA Henintsoa Jerry

Date : Mercredi 21 Octobre 2026

Périmètre	Les traitements de la plateforme : identité, facturation, détection de fraude, assistant documentaire, audit, sauvegardes
Référentiel	Règlement (UE) 2016/679 (RGPD), lignes directrices CNIL, droit national applicable

1. Synthèse

La plateforme traite des données personnelles sensibles : identité des assurés, actes de santé, montants, dates, prestataires, scores de fraude et explications de la note. Le cadre est donc celui de la vigilance renforcée : on collecte le minimum, on remplace les identités par des pseudonymes, on chiffre, on cloisonne les accès, on borne la durée de conservation, et on organise les droits des personnes.

Ce qui est en place et démontrable :

- les noms et coordonnées sont isolés dans une table chiffrée ;
- les factures ne portent qu'un pseudonyme stable ;
- les accès sont filtrés côté serveur, par rôle et par dossier ;
- les droits d'export, de rectification, d'opposition et d'effacement sont implémentés ;
- les durées de conservation sont codées : 3 ans pour les prédictions, 10 ans pour les factures, 5 ans pour le journal d'audit, et une purge les applique automatiquement toutes les 24 h, de façon traçable ;
- les sauvegardes sont chiffrées quand la clé est fournie ;
- les connexions et les actions sensibles sont journalisées.

Ce qui manque encore :

- le droit à la limitation n'est pas implémenté ;
- l'effacement ne purge pas immédiatement les sauvegardes ;
- la rectification, l'opposition et l'effacement passent par un administrateur, sans écran en libre-service pour la personne concernée ;
- le registre des traitements formel, la désignation du DPO, les contrats de sous-traitance et l'AIPD restent à finaliser ;
- la procédure de notification d'une violation sous 72 heures n'est pas écrite ;
- les transferts hors UE et les clauses contractuelles types restent à documenter.

2. Rôles et gouvernance

2.1. Répartition des rôles

Acteur	Rôle RGPD	Commentaire
Assureur client	Responsable de traitement	Détermine les finalités, les moyens et les durées

L'éditeur de la plateforme	Sous-traitant	Héberge, maintient et exploite pour le compte de l'assureur
OpenAI	Sous-traitant ultérieur	Reçoit les questions, les extraits de contrats et l'historique minimisé
Slack	Sous-traitant de notification	Reçoit une référence de facture, un score et un rapport d'explication
Hébergeur	Sous-traitant	Héberge la base, les sauvegardes et les artefacts
DPO	À désigner	Point de contact, registre, AIPD, conseil
Gestionnaire	Personne habilitée	Décide après examen humain, dans le périmètre de son rôle
Administrateur	Personne habilitée	Gère les comptes, les droits RGPD, les seuils et les secrets

Cette répartition doit être confirmée par le contrat de déploiement. Si l'éditeur de la plateforme détermine lui-même les finalités ou les moyens, il devient responsable de traitement et les obligations changent. Ce document ne présume pas la qualification contractuelle.

2.2. Gouvernance à mettre en place

Élément	État	Action
Registre des traitements	Première version dans ce document	Reprendre dans l'outil du DPO
Désignation du DPO	Non formalisée	Désigner et publier le contact
Politique de conservation	Codée, purgée, pas encore approuvée	Faire valider les durées
AIPD	Matière fournie, non réalisée	Réaliser et consulter le DPO
Contrats de sous-traitance	Connus, non signés	Signer les DPA et clauses de transfert
Procédure de violation	Non écrite	Rédiger le runbook 72 h
Formation des utilisateurs	Non formalisée	Former au score, à l'humain et à la confidentialité
Revue annuelle	Non planifiée	Fixer une revue de conformité

3. Registre des traitements

Le tableau ci-dessous est une proposition de registre. Les bases légales et les durées doivent être validées par le DPO.

Traitement	Personnes	Finalité	Base légale proposée	Conservation
Identité assuré	Assurés	Gestion du contrat	Exécution du contrat, art. 6.1.b	Durée du contrat + prescription
Facturation et remboursement	Assurés, prestataires	Prise en charge	Exécution du contrat ; obligation légale	10 ans pour les factures
Détection de fraude	Assurés, prestataires	Prévention de la fraude	Intérêt légitime, art. 6.1.f ; art. 9.2.f	3 ans pour les prédictions
Assistant documentaire	Assurés	Information contractuelle	Exécution du contrat, art. 6.1.b	Session 1 h ; logs 30 jours
Audit et décisions	Gestionnaires, administrateurs	Traçabilité et conformité	Obligation légale, art. 6.1.c	5 ans
Sauvegardes	Tous	Continuité et reprise	Intérêt légitime	14 jours
Notifications	Assurés, gestionnaires	Alerte opérationnelle	Exécution du contrat ; intérêt légitime	Selon le canal
Import de factures	Assurés, prestataires	Saisie et contrôle	Exécution du contrat ; minimisation	Même durée que les factures
Formation du modèle	Assurés (si données réelles)	Amélioration du modèle	À définir ; données synthétiques	Durée du projet

Deux points sont structurants :

- Les données de santé sont présentes dans les actes, les diagnostics et les ordonnances. L'article 9 du RGPD exige une base spécifique : l'article 9.2.f (constatation, exercice ou défense d'un droit en justice) ou l'article 9.2.h (médecine) doivent être retenus selon le montage. L'intérêt légitime de l'article 6 ne suffit pas à lui seul.
- Le score de fraude ne doit pas produire d'effet juridique automatique. La décision est humaine, tracée et contestable. C'est une mesure de conformité, pas seulement un choix produit.

L'import de factures PDF mérite une mention à part. Une facture au format PDF porte l'identité du patient en clair, là où le reste de la plateforme ne manipule qu'un pseudonyme. C'est un point d'entrée de données personnelles supplémentaire : il doit rester dans le périmètre autorisé, ne jamais être journalisé tel quel, et les fichiers doivent être purgés après traitement.

4. Bases légales et finalités

4.1. Gestion du contrat et remboursement

La base principale est l'exécution du contrat d'assurance. Les données de santé sont nécessaires à la prise en charge. La minimisation impose de ne collecter que les actes et les pièces utiles, et de ne pas afficher de noms dans les écrans de contrôle qui n'en ont pas besoin.

4.2. Détection de fraude

L'intérêt légitime est plausible : un assureur a un intérêt à prévenir la fraude et à maîtriser ses coûts. Mais il suppose une mise en balance :

- nécessité : le score aide à prioriser les contrôles, il ne remplace pas la décision ;
- proportionnalité : les faux positifs ne doivent pas retarder indûment un remboursement ;
- transparence : la personne doit être informée du traitement et de ses droits ;
- garanties : pseudonymisation, accès restreint, audit, décision humaine.

Une décision négative doit pouvoir être contestée. Le score n'est pas une preuve de fraude : c'est un signal de priorisation.

4.3. Assistant documentaire

L'assistant répond à des questions contractuelles. La base est l'exécution du contrat. Les questions peuvent contenir des données de santé ou des éléments de dossier : la minimisation consiste à ne pas demander de nom, à limiter la longueur, à cloisonner la session et à ne pas conserver l'historique au-delà d'une heure.

Le fournisseur de modèle reçoit la question, les extraits de contrats et l'historique. Il ne reçoit pas de noms si l'utilisateur n'en saisit pas. Le prompt système et les sources sont séparés de la question, pour limiter l'injection.

L'information des personnes est en place sur l'écran de l'assistant : la mention « Réponse générée par un assistant IA — vérifiez les sources citées » est affichée sous chaque réponse.

4.4. Audit et sécurité

Le journal d'audit est nécessaire pour prouver les décisions, détecter les accès anormaux et répondre à une violation. Il est conservé 5 ans, mais il est anonymisé en cas d'effacement d'un dossier. La tension entre obligation de traçabilité et droit à l'effacement est traitée explicitement : l'action et l'horodatage restent, le pseudonyme disparaît.

5. Minimisation et pseudonymisation

5.1. Mesures en place

Mesure	Implémentation	Preuve

Identités chiffrées	Fernet (AES-128-CBC + HMAC), clé dans l'environnement	packages/predicare-core/src/predicare/crypto.py
Pseudonyme stable	HMAC-SHA256 avec APP_SECRET_KEY	même fichier
Aucun nom dans les factures	core.facture ne porte que assure_id	migrations
Cloisonnement du cache	clé assure_id ou user:{subject}	apps/api-rag/.../main.py
Filtre SQL par assuré	compte lecture seule + paramètre lié	apps/api-rag/.../sql_tool.py
Filtre prestataire	facture.prestataire_id = prestataire du compte	apps/api-core/.../billing/router.py
Journal d'audit	acteur, rôle, action, cible, détails	audit.journal
Connexion tracée	action connexion	identity/router.py

5.2. Limites

Le pseudonyme est stable : il permet de relier les factures d'une même personne, ce qui est nécessaire au contrôle. Il ne rend donc pas la personne anonyme. La ré-identification reste possible si l'attaquant obtient la clé Fernet et la table des identités. C'est pourquoi la clé est séparée, chiffrée par l'environnement et rotative.

Les logs applicatifs peuvent contenir des références de factures, des scores et des identifiants pseudonymisés. Ils ne doivent pas contenir de noms, de coordonnées, de diagnostic en clair ni de jeton. Une revue des logs est nécessaire avant production — d'autant plus avec l'import de PDF, où le fichier source contient l'identité en clair.

6. Conservation et purge

6.1. Durées de conservation

Donnée	Durée	État
Identités chiffrées	Durée du contrat + prescription	À valider
Factures	10 ans	Codé et purgé
Prédictions	3 ans	Codé et purgé
Journal d'audit	5 ans	Codé et purgé
Sessions de l'assistant	1 heure	Codé dans Redis
Logs applicatifs	30 jours	Configuration à vérifier
Sauvegardes	14 jours	Codé
Cache sémantique	Durée du processus	En mémoire

Les durées sont surchargeables par audit.parametre pour les clés duree_conservation_*. La purge utilise une année de 365 jours, volontairement indépendante du calendrier bissextile.

6.2. Purge planifiée et traçable

La purge des données métier est implémentée dans predicare_core_api.rgpd.purge. Elle se déclenche de deux façons :

- automatiquement : api-core lance un premier passage différé, puis un toutes les 24 h. Chaque exécution réelle écrit une ligne dans audit.journal, action purge_planifiee, avec le nombre de lignes supprimées par table. La purge est idempotente : un second passage ne trouve plus rien à supprimer. La boucle se coupe avec PURGE_PLANIFIEE=0 ;
- à la main : make purge affiche l'aperçu, make purge ARGS=--appliquer exécute.

Un test vérifie qu'une donnée expirée n'est plus servie (tests/test_purge_planifiee.py).

Ce qui reste ouvert n'est plus la planification, c'est la preuve : la relecture des exécutions doit faire partie de la revue mensuelle, et la durée de conservation des logs applicatifs doit être fixée.

6.3. Sauvegardes

Les sauvegardes sont conservées 14 jours. Une demande d'effacement ne les purge pas immédiatement : les archives peuvent contenir le dossier jusqu'à leur rotation. Ce délai doit être expliqué dans la procédure de réponse à la personne. Si une restitution immédiate est exigée, il faut soit exclure le dossier des sauvegardes, soit restaurer et re-purger, soit réduire la rétention. Chaque option a un coût de continuité.

7. Droits des personnes

7.1. Vue d'ensemble

Droit	État	Modalité	Limite
Accès	Démontré	Export JSON du dossier	Admin ou assuré connecté
Portabilité	Démontré	Même export JSON	Format lisible, pas de schéma standard
Rectification	Démontré	PUT /rgpd/assures/{pseudonyme}/identite	Admin uniquement
Opposition	Démontré	POST /rgpd/assures/{pseudonyme}/opposition	Arrête le service, ne supprime pas
Effacement	Démontré	DELETE /rgpd/assures/{pseudonyme}	Admin uniquement ; sauvegardes différées

Limitation	Écart	Non implémenté	À définir
Décision automatisée	Partiel	Décision humaine, audit	Pas de contestation en libre-service

7.2. Export et portabilité

L'assuré connecté peut appeler GET /api/core/rgpd/moi/export. Le pseudonyme vient du jeton, jamais de l'URL : un assuré ne peut pas exporter le dossier d'un autre. L'administrateur peut exporter n'importe quel dossier avec GET /api/core/rgpd/assures/{pseudonyme}/export.

L'export contient l'identité déchiffrée, les factures, les ordonnances, les prédictions, l'état d'opposition et la date de génération. Il est servi en JSON, avec un en-tête de téléchargement côté interface. C'est une base de portabilité, mais pas un format standardisé RGPD ; il faudra le documenter.

7.3. Rectification

L'administrateur peut corriger le nom, les coordonnées et la date de naissance. La valeur est rechiffrée immédiatement ; elle n'est jamais stockée en clair. L'action est journalisée. Il n'y a pas d'écran en libre-service pour l'assuré : la demande passe par le support ou le DPO.

7.4. Opposition

L'opposition met un drapeau sur le dossier. Les factures ne sont plus servies à l'assuré, mais elles ne sont pas supprimées. L'opposition ne s'applique pas à la prospection, qui n'est pas dans le périmètre. Il faut définir ce que l'opposition signifie pour les traitements obligatoires : elle ne peut pas faire obstacle à une obligation légale.

7.5. Effacement

L'effacement supprime :

- l'identité chiffrée ;
- les factures et leurs lignes ;
- les ordonnances et leurs lignes ;
- les prédictions et les explications associées ;
- les étiquettes d'entraînement liées aux factures ;
- les contrats, garanties et bénéficiaires ;
- le lien entre le compte et le dossier.

Il conserve le journal d'audit, mais remplace le pseudonyme par [EFFACE] dans les détails et les cibles. Il journalise l'effacement sans pseudonyme. C'est une décision explicite : la traçabilité de l'effacement prime, mais elle ne permet plus de ré-identifier la personne.

7.6. Limitation

Le droit à la limitation n'est pas implémenté. Une personne qui conteste un traitement ne peut pas demander le gel de ses données par une API. C'est un écart à traiter avant production. La limitation peut être approchée par un statut de dossier et une exclusion temporaire des traitements, mais elle doit être conçue, testée et auditée.

7.7. Procédure de réponse

Étape	Contenu	Délai
1. Réception	Canal support, DPO ou formulaire	Jour 0
2. Vérification d'identité	Ne pas divulguer à un tiers	Jour 0–2
3. Qualification	Accès, rectification, opposition, effacement, limitation	Jour 2
4. Exécution	Export, mise à jour, drapeau, suppression	Jour 2–20
5. Réponse	Confirmation, limites, sauvegardes	Jour 30
6. Archivage	Preuve de la demande et de la réponse	5 ans

Le délai légal est d'un mois, prolongeable de deux mois pour les demandes complexes. L'identité doit être vérifiée avant tout export. Une demande d'effacement ne doit pas supprimer les données nécessaires à une obligation légale sans analyse.

8. Analyse d'impact (AIPD)

8.1. Justification de l'AIPD

Le traitement combine données de santé, scoring, décision financière et population potentiellement vulnérable. Ces caractéristiques sont susceptibles d'engendrer un risque élevé. Une analyse d'impact est donc requise avant production.

8.2. Risques et mesures

Risque	Gravité	Mesures existantes	Risque résiduel
Faux positif : retard de remboursement	Moyenne	Décision humaine, commentaire, audit	Moyen
Biais défavorable à un segment	Moyenne	Audit d'équité, supervision	Moyen
Ré-identification	Élevée	Chiffrement, pseudonymisation, clé séparée	Faible
Fuite vers le fournisseur de modèle	Élevée	Minimisation, pas de noms, DPA à signer	Moyen
Injection de prompt	Moyenne	Filtre, séparation, SQL lecture seule	Faible

Accès indu d'un professionnel	Moyenne	Filtre prestataire_id corrigé	Faible
Sauvegarde compromise	Moyenne	Chiffrement AES-256, clé fichier	Faible
Perte de clé	Moyenne	Sauvegarde de clé, rotation	Moyen
Journal non purgé	Moyenne	Purge planifiée et tracée	Faible
Sous-traitant hors UE	Élevée	DPA, clauses, minimisation	Moyen

8.3. Consultation du DPO

Si l'AIPD conclut à un risque résiduel élevé malgré les mesures, le DPO doit consulter l'autorité de contrôle avant le traitement. Ce n'est pas le cas aujourd'hui dans la documentation, mais la conclusion doit être écrite.

9. Sous-traitants et transferts

Destinataire	Données reçues	Localisation	Mesure
OpenAI	Question, extraits de contrats, historique	États-Unis (à confirmer)	DPA, clauses contractuelles types, minimisation
Slack	Référence facture, score, explication	États-Unis	Workspace privé, DPA
E-mail	Référence, score, lien	Selon fournisseur	DPA, chiffrement
Hébergeur	Base, sauvegardes, artefacts	À choisir	DPA, localisation UE, chiffrement
BI	Données agrégées, pas de noms	Même serveur	Accès restreint, jeton d'invité

Les transferts hors UE ne sont pas encore documentés. Avant production, il faut :

- vérifier la localisation réelle du fournisseur de modèle ;
- signer les clauses contractuelles types et réaliser une analyse d'impact du transfert ;
- mettre à jour le registre ;
- prévoir un repli si le fournisseur change ;
- ne pas envoyer de données non minimisées.

10. Violations de données

10.1. Procédure cible

1. Détecter : alerte, logs, signalement interne, audit.

2. Qualifier : nature, volume, personnes, données concernées, gravité.

3. Confiner : révoquer les accès, isoler le service, préserver les preuves.

4. Notifier : autorité sous 72 heures si risque ; personnes si risque élevé.

5. Corriger : correctif, rotation, restauration.

6. Documenter : registre des violations, retour d'expérience.

10.2. État des mesures

La procédure n'est pas encore écrite. Les journaux et l'audit fournissent la matière, mais il manque un runbook, un annuaire d'escalade et un modèle de notification. C'est un écart P1 avant production.

11. Sécurité et conformité

Le document 04 couvre les mécanismes techniques. Pour le RGPD, les contrôles clés sont :

- chiffrement des identités et des sauvegardes ;
- pseudonymisation et cloisonnement ;
- RBAC et filtres serveur ;
- journalisation des connexions, décisions et actions RGPD ;
- rotation des clés ;
- sauvegarde et restauration ;
- test d'intrusion ;
- minimisation des données envoyées au fournisseur de modèle.

La sécurité n'est pas une conformité à elle seule : un contrôle technique sans procédure, sans preuve et sans responsable ne suffit pas. Le tableau de conformité ci-dessous relie chaque obligation à une preuve.

12. Matrice de conformité

Obligation	Preuve	Statut	Écart / action
Registre des traitements	Ce document	Partiel	Reprendre dans l'outil DPO
Bases légales	Ce document	Partiel	Validation DPO/juriste
Minimisation	Pseudonymisation, filtres	Démontré	Revue des logs
Durées de conservation	conservation.py	Démontré	Suivre les exécutions de purge
Droit d'accès	Export JSON	Démontré	Documentation utilisateur
Droit de rectification	API admin	Démontré	Interface libre-service à décider

Droit d'opposition	API admin	Démontré	Définir les effets
Droit d'effacement	API admin	Démontré	Sauvegardes différées
Droit à la limitation	Absent	Écart	Concevoir et tester
Information des personnes	Mention IA affichée	Partiel	Généraliser l'explication du score
AIPD	Matière fournie	Écart	Réaliser
DPO	Non désigné	Écart	Désigner
Contrats sous-traitants	Non signés	Écart	Signer
Transferts hors UE	Non documentés	Écart	DPA + analyse de transfert
Violation 72 h	Non écrite	Écart	Runbook
Formation	Non formalisée	Écart	Former
Revue annuelle	Non planifiée	Écart	Planifier

13. Plan d'action

Action	Priorité	Responsable	Échéance	Preuve attendue
Désigner le DPO	P0	Direction	Avant production	Lettre de désignation
Valider les bases légales	P0	DPO/juriste	Avant production	Avis écrit
Réaliser l'AIPD	P0	DPO + RSSI	Avant production	AIPD signée
Implémenter la limitation	P1	Produit	Avant production	API + test
Écrire la procédure 72 h	P1	RSSI	Avant production	Runbook
Signer les DPA	P1	Direction	Avant production	Contrats
Documenter les transferts	P1	DPO	Avant production	Analyse de transfert
Documenter le sort des sauvegardes	P1	DPO	Avant production	Note dans la procédure
Fixer la durée de conservation des logs	P2	Exploitation	Avant production	Configuration
Ajouter l'écran de demande de droits	P2	Produit	Après production	Parcours testé
Former les utilisateurs	P2	Direction	Lancement	Support de formation

14. Conclusion

La plateforme dispose de fondations techniques sérieuses : pseudonymisation, chiffrement, filtres serveur, droits RGPD, conservation codée et purgée, audit. Ces fondations ne suffisent pas à déclarer une conformité complète. La différence entre « le code fait ce qu'il faut » et « l'organisation peut le prouver » reste à combler : DPO, AIPD, registre, contrats, procédure de violation et droit à la limitation.

La feuille de route est donc claire : sécuriser les preuves documentaires, organiser les opérations, puis faire valider l'ensemble par le DPO et le juriste. Tant que ces étapes ne sont pas faites, le statut correct est conformité par conception, conformité organisationnelle partielle, pas de certification.

15. Annexes

Cartographie simplifiée

Assuré

- identité chiffrée (nom, coordonnées, date de naissance)
- pseudonyme stable
- factures / lignes / ordonnances
- prédictions / explications
- export RGPD
- opposition / effacement

Gestionnaire

- file d'alertes
- décision + commentaire
- audit

Administrateur

- comptes et rôles
- seuil et modèle
- droits RGPD
- secrets / rotation

Sous-traitants

- OpenAI : question, extraits, historique
- Slack : référence, score, explication
- hébergeur : base, sauvegardes